

NETWORKWALKS

Penetration Testing Report

Mediroza General Hospital
Batch B082 | Week 4

Client	Mediroza General Hospital
Assessment Type	Black-box Penetration Test
Target	https://medirozahospital.com
Assessment Duration	3 Days

Confidential — Authorised Personnel Only

1. Executive Summary

A controlled black-box penetration test was performed against Mediroza General Hospital's authorised web target. The assessment identified a chain of weaknesses beginning with username enumeration and SQL injection in the patient login, progressing to authentication bypass and access to protected patient reports, and culminating in public exposure of an old database backup. The backup contained confidential staff salary and shareholder information.

The highest-risk issues are the SQL injection authentication bypass and the publicly exposed database backup/directory. Together, these weaknesses demonstrate that an attacker could move from a public web login to sensitive application data and then to highly confidential internal records.

Overall risk: CRITICAL. Immediate remediation should prioritize parameterized database queries, proper authentication controls, removal of public backups, and strict access controls for patient documents.

2. Scope and Methodology

The project guide states that testing was authorised in a controlled educational environment and was limited to the target domain. No social engineering, denial-of-service testing, or testing outside the agreed scope was performed.

Methodology followed the project milestones:

- M1 — Reconnaissance, authentication testing, SQL injection validation, authentication bypass, and retrieval of three patient PDF reports.
- M2 — Analysis of PDF encryption, password recovery, and creation of an unlocked copy for metadata analysis.
- M3 — PDF metadata analysis, discovery of the /old/ directory, retrieval of the exposed SQL backup, and analysis of staff/shareholder records.
- M4 — Risk assessment, findings documentation, and remediation recommendations.

Tools used included curl, Nmap, Burp Suite, pdftinfo, pdf2john, qpdf, exiftool, grep/awk, wget, and the Networkwalks hash/password-cracking utilities.

3. Findings and Proof of Exploitation

F-01 — Username Enumeration [Medium]

Location	patient/login.php
Description	Different error messages were returned for a nonexistent username and a valid username with an incorrect password.
Evidence / Proof	bob / test123 → "Username not found"; admin / test123 → "Incorrect password".

Remediation	Use a single generic authentication failure message and avoid revealing whether an account exists.
-------------	--

F-02 — SQL Injection Authentication Bypass [Critical]

Location	patient/login.php
Description	A single quote in the username caused a MySQL syntax error, demonstrating unsafe construction of the SQL query. A crafted username then bypassed authentication.
Evidence / Proof	admin' → MySQL syntax error. The authorised test payload admin' -- resulted in the patient portal loading without a valid password.
Remediation	Use parameterized queries/prepared statements, validate input, and never concatenate raw user input into SQL statements.

F-03 — Protected Patient Reports Accessible After Bypass [High]

Location	patient/reports/
Description	Successful authentication bypass exposed three patient laboratory reports that were intended to be restricted.
Evidence / Proof	patient_report_1.pdf, patient_report_2.pdf, and patient_report_3.pdf were retrieved from the portal.
Remediation	Store patient documents outside the public web root or enforce strong server-side authorization checks on every file request.

F-04 — Weak PDF Passwords [High]

Location	patient_report_*.pdf
Description	The retrieved PDFs were encrypted but used passwords recoverable with wordlists.
Evidence / Proof	Report 1 → 123456; Report 2 → password; Report 3 → !@#%\$^&.
Remediation	Use strong, unique, randomly generated passwords or, preferably, enforce access control at the application/storage layer instead of relying on weak document passwords.

F-05 — Sensitive PDF Metadata [Medium]

Location	patient_report_3.pdf
Description	After decryption, metadata exposed an internal username and an operational note pointing to a backup location.
Evidence / Proof	Author: j.malik. Comments: DB backup moved to /old before site migration, do not delete.
Remediation	Strip unnecessary metadata before distributing patient documents and review generated PDF metadata during release processes.

F-06 — Public Old Directory and Database Backup Exposure [Critical]

Location	/old/
Description	Directory listing was enabled and exposed an old database backup directly from the web server.
Evidence / Proof	https://medirozahospital.com/old/ listed mediroza_db_backup_2019.sql, which was downloaded successfully with wget.
Remediation	Disable directory listing, remove obsolete backups, keep backups outside the web root, and apply authentication/access controls to backup storage.

F-07 — Confidential Staff and Shareholder Data Exposure [Critical]

Location	/old/mediroza_db_backup_2019.sql
Description	The publicly accessible SQL backup contained staff salary information and shareholder records in plaintext.
Evidence / Proof	The backup contained 30 staff records and 10 shareholder records, including monthly salaries, share percentages, and share classes.
Remediation	Immediately remove the exposed backup, rotate/revoke any related credentials or secrets, restrict backup access, and implement secure backup retention and storage procedures.

4. Risk Rating Summary

ID	Finding	Risk	Primary Impact
F-01	Username enumeration	Medium	Account discovery
F-02	SQL injection authentication bypass	Critical	Authentication compromise
F-03	Patient reports accessible after bypass	High	Confidential patient data exposure
F-04	Weak PDF passwords	High	Document confidentiality weakened
F-05	Sensitive PDF metadata	Medium	Internal information disclosure
F-06	Public /old/ directory and backup	Critical	Direct sensitive file exposure
F-07	Staff salaries/shareholder data exposed	Critical	Confidential business/HR data exposure

5. M1–M3 Attack Chain

1. robots.txt revealed /patient/, /staff/, and /old/.
2. The patient login exposed account existence through different error messages.
3. A single quote triggered a MySQL syntax error, confirming SQL injection.
4. The authorised SQL injection test bypassed the login and exposed three reports.
5. The three PDFs were downloaded and their encryption was analysed.
6. Report 1, Report 2, and Report 3 passwords were recovered as 123456, password, and !@#%& respectively.
7. Report 3 metadata revealed Author j.malik and a note pointing to /old/.
8. The /old/ directory was publicly browsable and exposed mediroza_db_backup_2019.sql.
9. The backup contained 30 staff records and 10 shareholder records.
10. The staff table linked Jameel Malik's email username (j.malik) to the PDF metadata clue; the solution identifies him as the IT Systems Administrator associated with the backup note.

6. Confidential Data Exposure — Staff Salaries

The following table summarizes the salary information required by the project deliverable. Unnecessary personal identifiers such as national IDs and telephone numbers are intentionally omitted from this report.

Name	Job Title	Department	Monthly Salary
Dr. Rajesh Naidoo	Chief Pathologist	Diagnostics Lab	ZAR 138,000
Sarah Botha	Chief Financial Officer	Finance	ZAR 152,000
Dr. Johan van der Merwe	Medical Director	Management	ZAR 160,000
Dr. Anita Naicker	Consultant Cardiologist	Cardiology	ZAR 132,000
Dr. Ahmed Kara	Consultant Physician	Internal Medicine	ZAR 128,000
Dr. Yusuf Cassim	Senior Registrar	Emergency & Trauma	ZAR 74,000
Michael Roberts	HR Director	Human Resources	ZAR 96,000
Susan Pretorius	HR Officer	Human Resources	ZAR 32,000
Jameel Malik	IT Systems Administrator	IT	ZAR 58,000
Thabo Molefe	Network Engineer	IT	ZAR 46,000
Nomvula Khumalo	Registered Nurse	Emergency & Trauma	ZAR 34,000
Lerato Mokoena	Registered Nurse	Pediatrics	ZAR 33,000
Bongani Ndlovu	Registered Nurse	Cardiology	ZAR 35,000
Zanele Mahlangu	Nursing Sister	Theatre	ZAR 42,000
Kagiso Sithole	Pharmacist	Pharmacy	ZAR 61,000
Naledi Zulu	Pharmacy Assistant	Pharmacy	ZAR 26,000
Themba Nkosi	Radiographer	Radiology	ZAR 44,000
Palesa Radebe	Radiographer	Radiology	ZAR 43,000
Deepak Pillay	Lab Technologist	Diagnostics Lab	ZAR 41,000
Kavitha Govender	Lab Technician	Diagnostics Lab	ZAR 35,000
Dr. Suresh Moodley	Consultant Radiologist	Radiology	ZAR 130,000
Dr. Fatima Patel	Pediatrician	Pediatrics	ZAR 118,000
Nisha Singh	Physiotherapist	Rehabilitation	ZAR 48,000
Dr. Vikram Chetty	Anaesthetist	Theatre	ZAR 135,000
David Smith	Facilities Manager	Operations	ZAR 52,000
Karen O'Connor	Billing Administrator	Finance	ZAR 29,000

James Wilson	Security Supervisor	Operations	ZAR 27,000
Linda Fourie	Receptionist	Front Office	ZAR 19,000
Peter van Wyk	Procurement Officer	Supply Chain	ZAR 38,000
Andile Mbeki	Ward Clerk	Administration	ZAR 21,000

7. Confidential Data Exposure — Shareholders

Shareholder	Share Percentage	Share Class
Dr. Rajesh Naidoo	18%	Ordinary
Cedar Health Holdings (Pty) Ltd	15%	Ordinary
Dr. Johan van der Merwe	12%	Ordinary
Reddy Family Trust	11%	Ordinary
Thabo Molefe	10%	Ordinary
Sarah Botha	9%	Ordinary
Dr. Ahmed Kara	8%	Preferential
Naledi Zulu	7%	Ordinary
Michael Roberts	6%	Ordinary
Dr. Vikram Chetty	4%	Preferential

8. Recommendations and Remediation Plan

Immediate / Critical: Remove mediroza_db_backup_2019.sql and any other database backups from publicly accessible web directories. Disable directory listing on /old/ and all similar locations.

Immediate / Critical: Replace raw SQL construction in the patient login with parameterized queries/prepared statements and validate inputs server-side.

Immediate / Critical: Review patient-report authorization. Patient documents must not be retrievable solely because a user reaches the reports page; enforce authorization on every document request.

High: Replace weak PDF passwords with strong unique secrets and assess whether PDF password protection is necessary when proper application-level access control is available.

High: Audit the web root and server storage for other backups, old application copies, temporary exports, database dumps, and directory listings.

Medium: Return the same generic login failure message for invalid usernames and invalid passwords.

Medium: Strip unnecessary metadata from patient-facing PDFs and verify generated documents before publication.

Ongoing: Implement backup retention, access control, encryption at rest, secure storage outside the web root, and periodic external exposure checks.

9. Evidence Collected

- robots.txt output showing /patient/, /staff/, and /old/.
- Patient login screenshots showing username enumeration responses.
- SQL injection database error after the single-quote test.
- Successful login-bypass result showing three patient reports.
- Downloaded patient_report_1.pdf, patient_report_2.pdf, and patient_report_3.pdf.
- PDF encryption/hash evidence and recovered passwords.
- Unlocked report3_open.pdf and exiftool metadata output.
- Browser screenshot of the public /old/ directory listing.
- wget output confirming successful retrieval of mediroza_db_backup_2019.sql.
- Terminal output showing staff and shareholder records in the SQL backup.

10. Conclusion

The assessment demonstrated a complete compromise chain from public reconnaissance to authentication bypass and exposure of confidential application and business data. The combination of SQL injection, weak authentication behavior, publicly reachable patient reports, and an exposed database backup creates a significant overall risk. The Critical findings should be remediated first, followed by the High and Medium findings, and the fixes should be verified through a follow-up security assessment.

End of Report